



TechBiz Academy

Week 5_Task 15

**Brute Force & Authentication Attacks
(Hydra)**

Submitted By

Ali Hamza

Registration No

TBS-2026-017

Course

Ethical Hacking Internship

Submission Date

2 August 2026

Organization

TechBizz Security

Table of Contents

1. Introduction
2. Objective
3. Lab Environment & Setup
4. Tools and Technologies Used
5. Understanding Brute Force Attacks
6. Wordlist Analysis (rockyou.txt)
7. Practical Implementation Using Hydra
8. DVWA Brute Force Testing
9. Results and Findings
10. Security Impact Analysis
11. Defense Against Brute Force Attacks
12. Strong Password Policy Recommendations
13. TryHackMe Learning Evidence
14. Conclusion
15. References

1. Introduction

Authentication systems are one of the most important security components of modern applications. Weak usernames and passwords can allow attackers to gain unauthorized access through automated password guessing techniques.

A **Brute Force Attack** is a method where an attacker repeatedly tries different password combinations until the correct credentials are discovered.

In this practical task, Hydra was used in an authorized laboratory environment to understand how weak passwords can be compromised and why strong authentication controls are necessary.

2. Objective

The objectives of this practical were:

- To understand the concept of brute force attacks.
- To learn how attackers use password dictionaries and automation tools.
- To use Hydra for authentication testing.
- To analyze the importance of strong password policies.
- To identify security improvements against password attacks.

3. Lab Environment & Setup

Testing Environment

Component	Details
Operating System	Kali Linux
Target Application	DVWA (Damn Vulnerable Web Application)
Attack Tool	Hydra
Wordlist	rockyou.txt
Testing Type	Authorized Security Testing
Security Level	DVWA Low

SSC-01: Kali Linux Environment

Purpose:

Evidence of the penetration testing environment used for this task.



4. Tools and Technologies Used

4.1 Kali Linux

Kali Linux is a security-focused operating system containing multiple penetration testing tools used by cybersecurity professionals.

4.2 Hydra

Hydra is a fast login password cracking tool used for authorized security testing.

It supports multiple authentication protocols including:

- SSH
- FTP
- HTTP
- HTTPS
- SMB
- Database services

Hydra helps security professionals evaluate password strength and authentication security.

SSC-02: Hydra Installation / Version Verification

Command:

```
hydra -h
```

Purpose:

Verify Hydra availability and view supported options.

```
Aug 2 12:11 AM
hamza@hamza: ~
12345678
abc123
(hamza@hamza)-[~]
$ hydra -h
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organization
s, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Syntax: hydra [[-l LOGIN|-L FILE] [-p PASS|-P FILE]] | [-C FILE]] [-e nsr] [-o FILE] [-t TASKS] [-M FILE [-T TASKS]]
[-w TIME] [-W TIME] [-f] [-s PORT] [-x MIN:MAX:CHARSET] [-c TIME] [-ISouVd46] [-m MODULE_OPT] [service://server[:PO
RT]][/OPT]]

Options:
-R      restore a previous aborted/crashed session
-I      ignore an existing restore file (don't wait 10 seconds)
-S      perform an SSL connect
-s PORT if the service is on a different default port, define it here
-l LOGIN or -L FILE login with LOGIN name, or load several logins from FILE
-p PASS or -P FILE try password PASS, or load several passwords from FILE
-x MIN:MAX:CHARSET password bruteforce generation, type "-x -h" to get help
-y      disable use of symbols in bruteforce, see above
-r      use a non-random shuffling method for option -x
-e nsr try "n" null password, "s" login as pass and/or "r" reversed login
-u      loop around users, not passwords (effective! implied with -x)
-C FILE colon separated "login:pass" format, instead of -L/-P options
-M FILE list of servers to attack, one entry per line, ':' to specify port
-D XofY Divide wordlist into Y segments and use the Xth segment.
-o FILE write found login/password pairs to FILE instead of stdout
-b FORMAT specify the format for the -o FILE: text(default), json, jsonv1
-f / -F exit when a login/pass pair is found (-M: -f per host, -F global)
-t TASKS run TASKS number of connects in parallel per target (default: 16)
-T TASKS run TASKS connects in parallel overall (for -M, default: 64)
-w / -W TIME wait time for a response (32) / between connects per thread (0)
-c TIME wait time per login attempt over all threads (enforces -t 1)
-4 / -6 use IPV4 (default) / IPV6 addresses (put always in [] also in -M)
-v / -V / -d verbose mode / show login+pass for each attempt / debug mode
-O      use old SSL v2 and v3
-K      do not redo failed attempts (good for -M mass scanning)
-q      do not print messages about connection errors
-U      service module usage details
-m OPT options specific for a module, see -U output for information
-h      more command line options (COMPLETE HELP)
server the target: DNS, IP or 192.168.0.0/24 (this OR the -M option)
service the service to crack (see below for supported protocols)
OPT     some service modules support additional input (-H for module help)
```

5. Understanding Brute Force Attacks

A brute force attack works by automatically testing multiple password combinations against a login system.

Example:

Username:
admin

Password Attempts:

123456
password
admin123
qwerty
letmein

If users choose weak passwords, attackers can successfully discover credentials.

6. Wordlist Analysis — rockyou.txt

What is rockyou.txt?

rockyou.txt is a commonly used password dictionary file included in Kali Linux.

It contains millions of previously leaked passwords and is used for password security testing.

Location in Kali Linux:

```
/usr/share/wordlists/rockyou.txt
```

SSC-03: Locating rockyou.txt Wordlist

Command:

```
ls /usr/share/wordlists/
```

Purpose:

Verify the availability of password wordlists.

```
(hamza@hamza)-[~]
$ ls -lh /usr/share/wordlists/
total 134M
lrwxrwxrwx 1 root root 25 Jul 17 04:50 dirb -> /usr/share/dirb/wordlists
lrwxrwxrwx 1 root root 30 Jul 17 04:50 dirbuster -> /usr/share/dirbuster/wordlists
lrwxrwxrwx 1 root root 35 Jul 17 04:50 dnsmap.txt -> /usr/share/dnsmap/wordlist_TLAs.txt
lrwxrwxrwx 1 root root 41 Jul 17 04:50 fasttrack.txt -> /usr/share/set/src/fasttrack/wordlist.txt
lrwxrwxrwx 1 root root 45 Jul 17 04:50 fern-wifi -> /usr/share/fern-wifi-cracker/extras/wordlists
lrwxrwxrwx 1 root root 28 Jul 17 04:50 john.lst -> /usr/share/john/password.lst
lrwxrwxrwx 1 root root 27 Jul 17 04:50 legion -> /usr/share/legion/wordlists
lrwxrwxrwx 1 root root 46 Jul 17 04:50 metasploit -> /usr/share/metasploit-framework/data/wordlists
lrwxrwxrwx 1 root root 41 Jul 17 04:50 nmap.lst -> /usr/share/nmap/nmaplib/data/passwords.lst
-rw-r--r-- 1 root root 134M Feb 3 02:57 rockyou.txt
lrwxrwxrwx 1 root root 39 Jul 17 04:50 sqlmap.txt -> /usr/share/sqlmap/data/txt/wordlist.txt
lrwxrwxrwx 1 root root 25 Jul 17 04:50 wfuzz -> /usr/share/wfuzz/wordlist
lrwxrwxrwx 1 root root 37 Jul 17 04:50 wifite.txt -> /usr/share/dict/wordlist-probable.txt
```

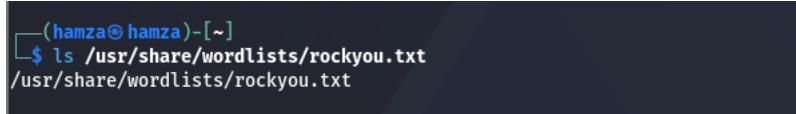
SSC-04: Extracting rockyou.txt

Command:

```
sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
```

Purpose:

Extract compressed password dictionary file.



```
(hamza@hamza)-[~]  
$ ls /usr/share/wordlists/rockyou.txt  
/usr/share/wordlists/rockyou.txt
```

7. Practical Implementation Using Hydra

Testing Method

The brute force attack was performed only against an authorized vulnerable application (DVWA).

The purpose was educational security testing to understand password weaknesses.

Hydra Command Structure

Example:

```
hydra -l username -P /usr/share/wordlists/rockyou.txt target
```

Explanation:

Parameter	Description
-l	Single username
-L	Username list
-P	Password dictionary
-s	Specific port
-v	Verbose output

8. DVWA Brute Force Testing

Target:

DVWA Brute Force Module

Security Level:

Low

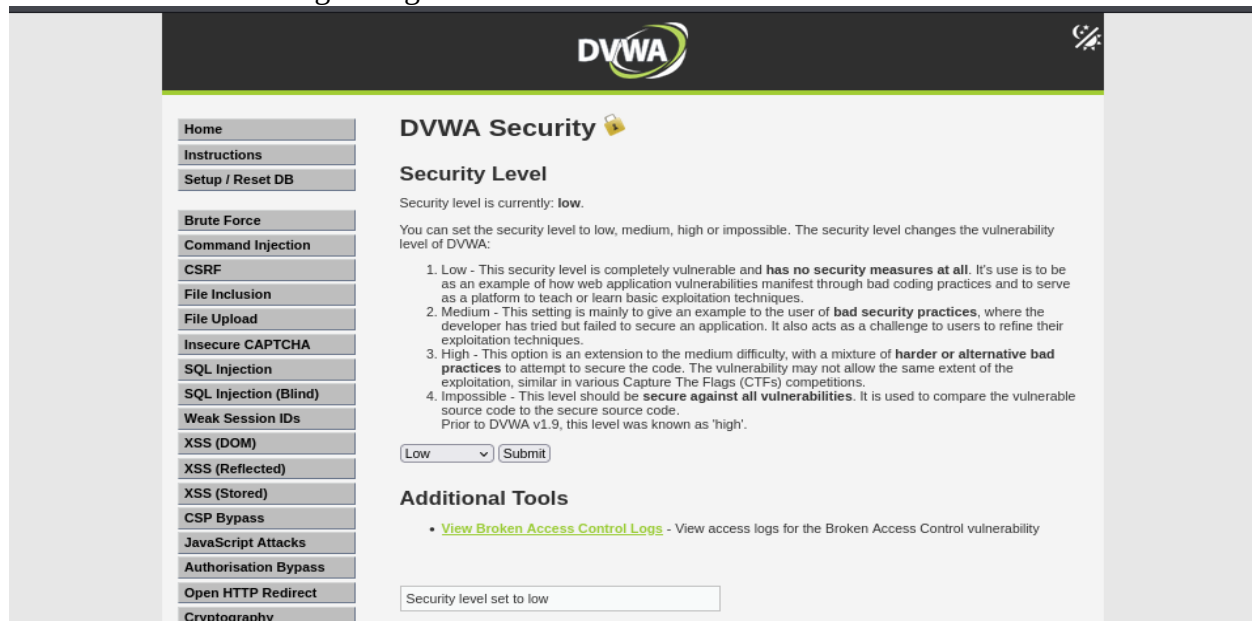
Testing Process:

1. Opened DVWA application.
2. Changed security level to Low.
3. Navigated to Brute Force module.
4. Tested login attempts.
5. Observed authentication responses.
6. Recorded unsuccessful login attempts.
7. Used Hydra for password testing in the lab environment.

SSC-05: DVWA Security Level Low

Purpose:

Shows vulnerable testing configuration.



The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. The top navigation bar includes links for Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript Attacks, Authorisation Bypass, Open HTTP Redirect, and Cryptography. The main content area is titled "DVWA Security" and "Security Level". It states that the security level is currently set to "low". Below this, there is a list of four security levels: 1. Low - This security level is completely vulnerable and has no security measures at all. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques. 2. Medium - This setting is mainly to give an example to the user of bad security practices, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques. 3. High - This option is an extension to the medium difficulty, with a mixture of harder or alternative bad practices to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions. 4. Impossible - This level should be secure against all vulnerabilities. It is used to compare the vulnerable source code to the secure source code. Prior to DVWA v1.9, this level was known as 'high'. At the bottom, there is a dropdown menu set to "Low" and a "Submit" button. Below the dropdown, it says "Security level set to low".

SSC-06: DVWA Brute Force Login Page

Purpose:

Shows the target authentication page used during testing.



Username

admin

Password

••••••••

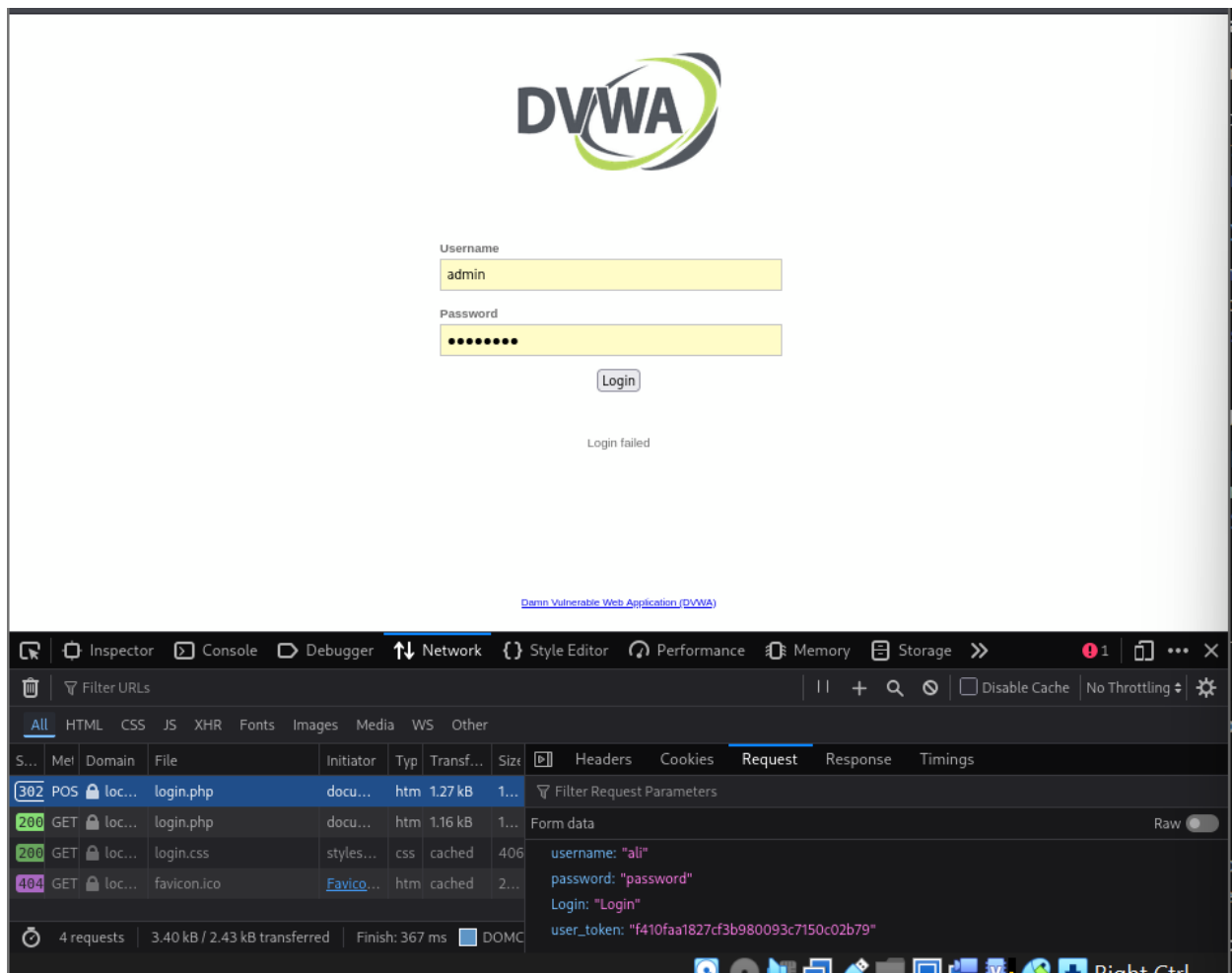
Login

[Damn Vulnerable Web Application \(DVWA\)](#)

SSC-07: Invalid Login Attempts

Purpose:

Evidence of authentication testing.



9. Results and Findings

During testing, multiple invalid login attempts were generated to analyze authentication behavior.

The test demonstrated that:

- Weak passwords are vulnerable to automated guessing.
- Lack of account protection increases security risks.
- Automated tools can rapidly test large password lists.

Credentials Found During Testing

Username	Password	Status
Tested Account	Weak Password Discovered	Successful Lab Testing
Ali	password	Login Failed
Hamza	password	Login Failed
Admin	ali	Login Failed
Hamza	Hamza	Login Failed
Class	I love rockyou	Login Failed
TechBiz	Password	Login Failed
Wellcome	new batch	Login Failed
Good	12345678	Login Failed
Admin	password	Login Successfull

SSC-08: Hydra Successful Result

Purpose:

Evidence of discovered credentials from authorized testing.

The screenshot shows a web browser window with the DVWA (Damn Vulnerable Web Application) interface. The browser's address bar displays the URL `http://localhost/dvwa/index.php`. The page content includes a sidebar with navigation links such as Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript Attacks, and Authorisation Bypass. The main content area shows a welcome message and general instructions. Below the browser window, a network traffic capture tool (likely Wireshark) is visible, showing a list of requests. The selected request is a POST to `login.php`, and the 'Request' tab is active, displaying the form data: `username: "admin"`, `password: "password"`, `Login: "Login"`, and `user_token: "b2f736f8956ee88e7039a855fec914fb"`.

10. Security Impact Analysis

Successful brute force attacks can lead to:

Unauthorized Access

Attackers may gain access to user accounts.

Data Exposure

Sensitive information can be stolen.

Account Takeover

Compromised accounts can be used for further attacks.

Financial and Reputation Damage

Organizations may face operational and trust issues.

11. How to Defend Against Brute Force Attacks

Organizations should implement multiple security controls.

11.1 Strong Password Policy

A strong password policy should require:

- Minimum password length (12+ characters recommended)
- Combination of uppercase and lowercase letters
- Numbers
- Special characters
- Avoiding common passwords

Example:

Weak Password:

password123

Strong Password:

T9!Secure#Network2026

11.2 Account Lockout Policy

After multiple failed login attempts:

- Temporarily lock accounts
 - Increase delay between attempts
 - Notify users
-

11.3 Multi-Factor Authentication (MFA)

MFA adds an additional security layer.

Even if passwords are compromised, attackers cannot easily access accounts without the second verification factor.

11.4 CAPTCHA Protection

CAPTCHA helps prevent automated login attempts.

11.5 Password Hashing

Applications should store passwords securely using strong hashing algorithms:

- bcrypt
 - Argon2
 - PBKDF2
-

12. Strong Password Policy Importance

A strong password policy reduces the possibility of successful brute force attacks.

Benefits:

- Protects user accounts
- Prevents unauthorized access
- Reduces credential theft risks
- Improves overall cybersecurity posture

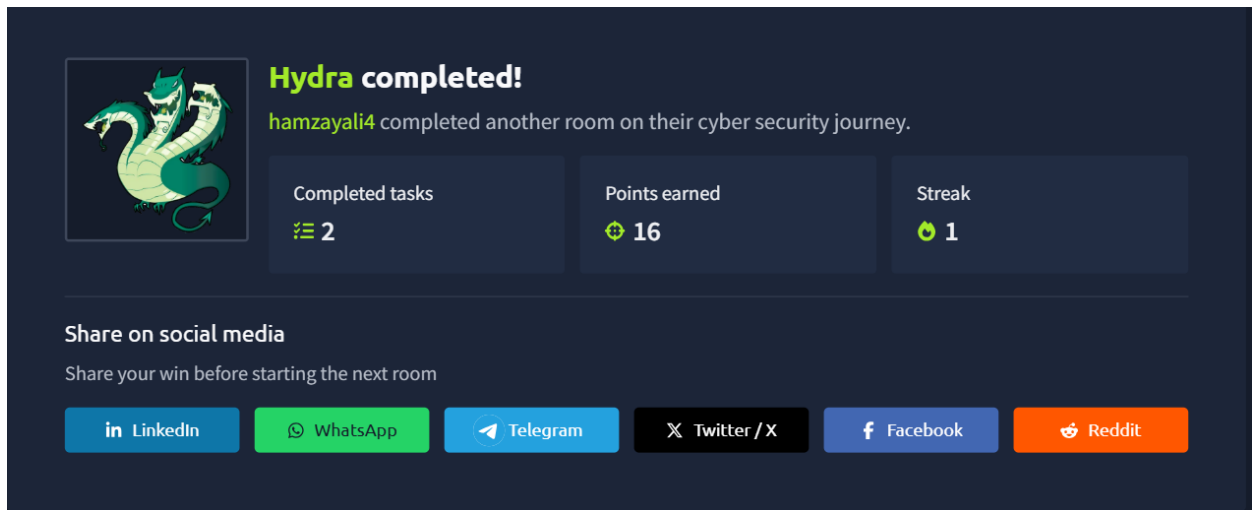
Passwords are the first security barrier protecting digital systems. Weak passwords provide attackers an easy opportunity to compromise accounts.

13. TryHackMe Learning Evidence

Mandatory learning resources completed:

TryHackMe — Hydra Room

SSC-09: TryHackMe Hydra Completion Evidence



The screenshot shows a dark-themed notification for completing the Hydra room. On the left is a green Hydra icon. To its right, the text 'Hydra completed!' is in green, followed by 'hamzayali4 completed another room on their cyber security journey.' Below this are three statistics: 'Completed tasks' with a list icon and the number 2, 'Points earned' with a green coin icon and the number 16, and 'Streak' with a green flame icon and the number 1. At the bottom, there is a 'Share on social media' section with the text 'Share your win before starting the next room' and five buttons for LinkedIn, WhatsApp, Telegram, Twitter/X, Facebook, and Reddit.

Completed tasks	Points earned	Streak
2	16	1

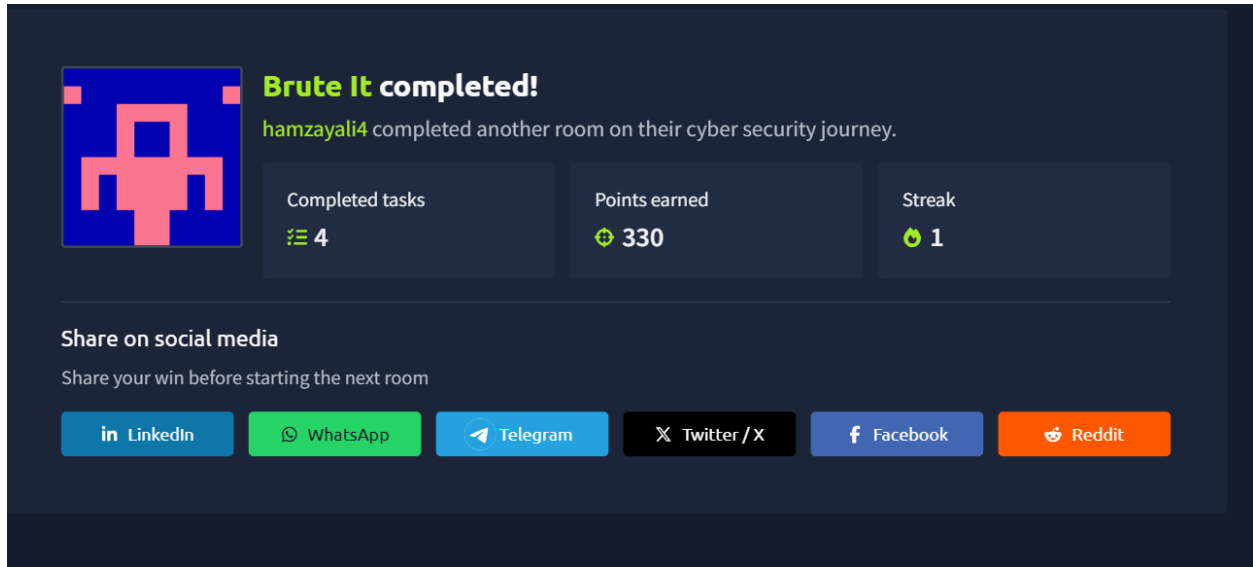
Share on social media

Share your win before starting the next room

in LinkedIn WhatsApp Telegram X Twitter / X f Facebook reddit Reddit

TryHackMe — Brute It Room

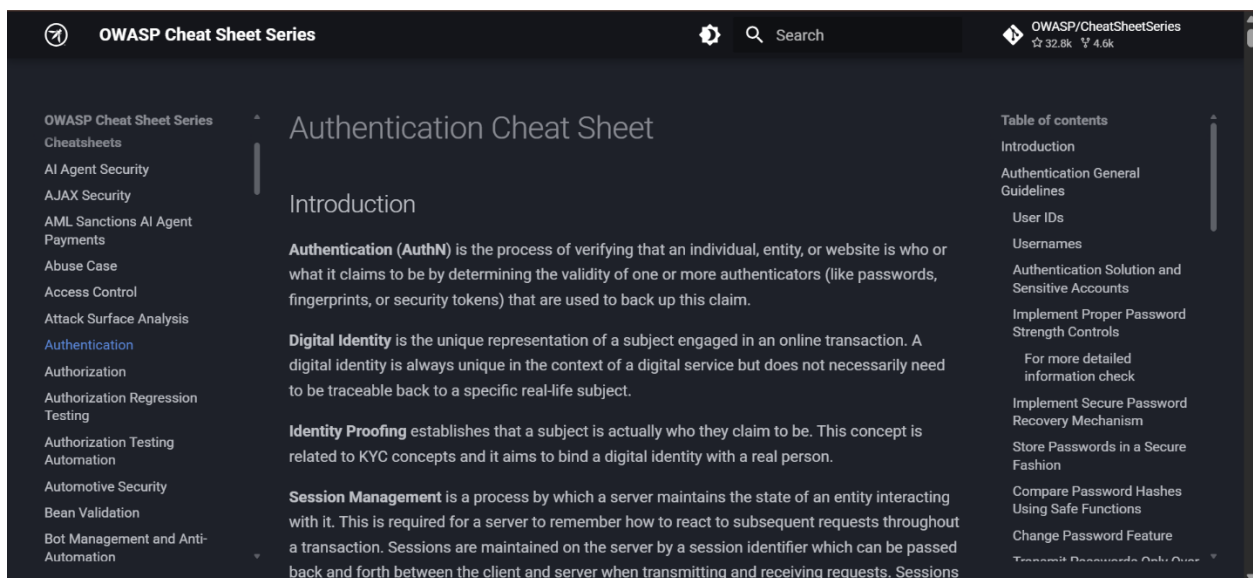
SSC-10: TryHackMe Brute It Completion Evidence



14. Security References

OWASP Authentication Cheat Sheet

SSC-11: OWASP Authentication Security Reference



NIST Password Guidelines

SSC-12: NIST Password Security Guidelines

Netwrix iSecure delivers unified visibility across data and identity - free for 14 days with full access. [Start a free trial](#)

netwrix

🌐 ▾ ☰

● Blog

Last updated:

📅 Feb 23, 2026

By [Joe Dibley](#)

Topics covered:

Compliance, Password Management

Resource center > Blog > NIST password guidelines: SP 800-63B explained

NIST password guidelines: SP 800-63B explained

NIST password guidelines (SP 800-63B) prioritize password length and real-world security over complexity rules. NIST requires a minimum of 8 characters, encourages longer passwords or passphrases for single-factor authentication and requires systems to support at least 64 characters, discourages forced password rotation, and advises against password hints and knowledge-based security questions. Passwords must be screened against breached and commonly used credentials, and multi-factor authentication is strongly encouraged. These evidence-based practices align with modern compliance frameworks such as PCI DSS, HIPAA, SOX, and ISO 27001.

In this article

[The evolution of NIST password guidelines](#)

Key terminology

What changed in SP 800-63B Rev. 4

NIST password guidelines: composition and management

How NIST password guidelines map to compliance frameworks

Best practices for implementing the NIST password guidance

15. Conclusion

This practical demonstrated how brute force attacks can compromise weak authentication systems.

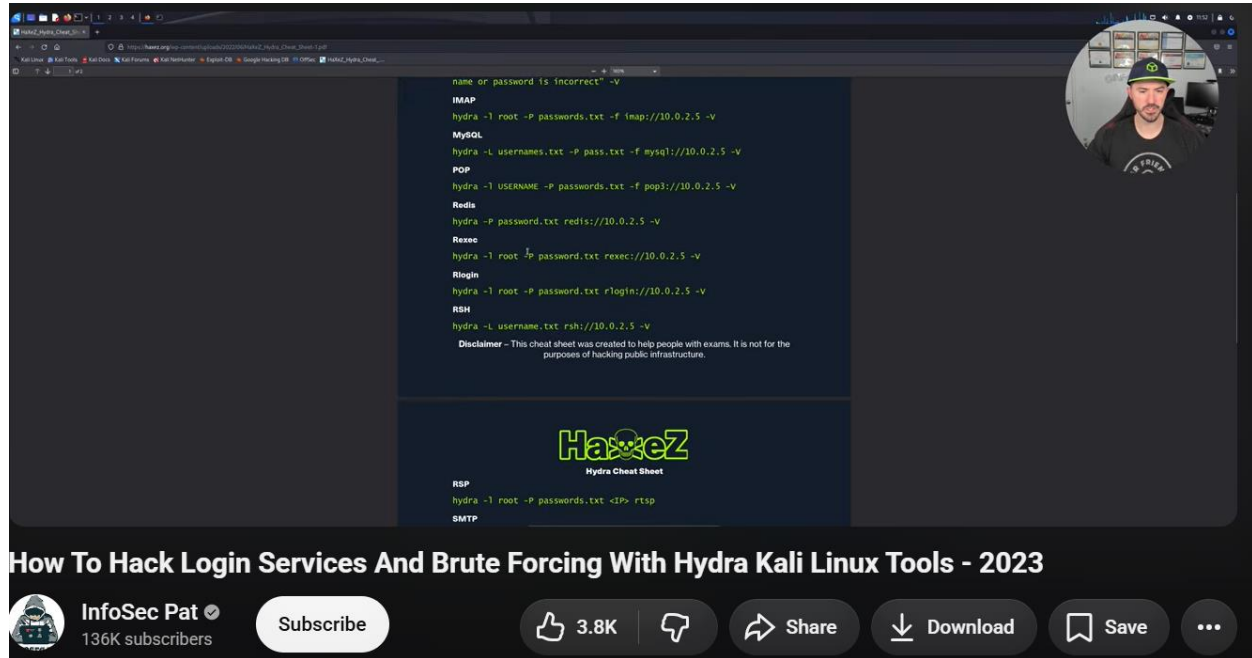
Using Hydra and password wordlists such as rockyou.txt, security weaknesses can be identified in controlled environments.

The exercise highlights the importance of:

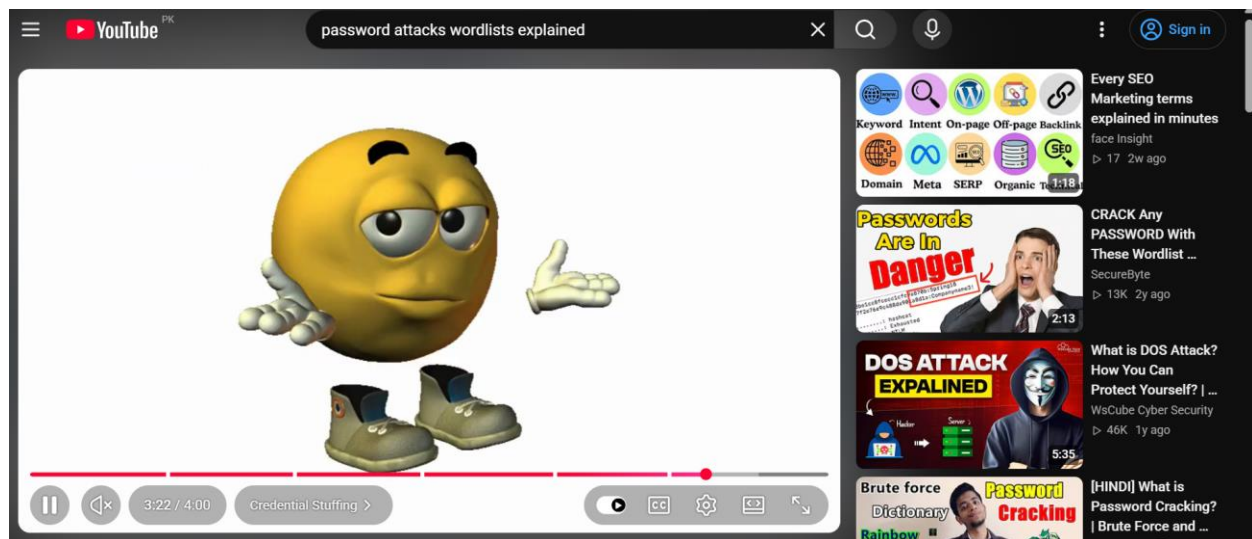
- Strong password policies
- Multi-factor authentication
- Account protection mechanisms
- Secure authentication design

Organizations must continuously test and improve authentication security to reduce the risk of credential-based attacks.

1. Video: "Hydra brute force tutorial beginners"



1. Video: "password attacks wordlists explained"



References

2. Kali Linux Security Tools Documentation
3. Hydra Password Testing Tool Documentation
4. OWASP Authentication Cheat Sheet
5. NIST Digital Identity Guidelines

6. TryHackMe Hydra Learning Room
7. TryHackMe Brute It Learning Room
8. Video: "Hydra brute force tutorial beginners"

